



Development Confirmation: Authentication & Onboarding Completion Checklist

Overview

Objective: Complete list of ALL features, components, and infrastructure required for authentication and onboarding to be considered **fully complete** before building actual applications (Inventory, Task Management, etc.).

Status: This is your MVP foundation. Do not proceed to app development until all items are checked.

Category 1: Core Authentication Infrastructure

1.1 User Account System

- ☐ **Database Schema**
 - ☐ users table (id, email, name, avatar, status, timestamps)
 - ☐ authIdentities table (password hash, OAuth providers, phone)
 - ☐ userSessions table (active sessions, devices, expiry)
 - ☐ userConsents table (terms, privacy, marketing consents)
 - ☐ userSecurityEvents table (login attempts, password changes)
 - ☐ userPreferences table (theme, language, timezone, notifications)
- ☐ **Authentication Methods**
 - ☐ Email/password authentication
 - ☐ Google OAuth (Authorization Code Flow with OIDC)
 - ☐ Facebook OAuth
 - ☐ Account linking (merge Google + email/password)
 - ☐ Password reset flow (email link)
 - ☐ Email verification (OTP or link)
- ☐ **Security Features**
 - ☐ Password hashing (bcrypt or Argon2)
 - ☐ Session management (JWT or secure cookies)

- ☐ Session revocation (logout, logout-all)
- ☐ Rate limiting on login/signup (prevent brute force)
- ☐ Account lockout after 5 failed attempts
- ☐ Secure password requirements (min 8 chars, strength meter)
- ☐ CSRF protection on all auth endpoints
- ☐ CORS configuration for multi-surface architecture
- ☐ **API Endpoints**
 - ☐ POST /v1/auth/register (email/password)
 - ☐ POST /v1/auth/login (email/password)
 - ☐ POST /v1/auth/oauth/:provider (Google, Facebook)
 - ☐ POST /v1/auth/verify-email
 - ☐ POST /v1/auth/resend-verification
 - ☐ POST /v1/auth/forgot-password
 - ☐ POST /v1/auth/reset-password
 - ☐ POST /v1/auth/logout
 - ☐ POST /v1/auth/logout-all
 - ☐ GET /v1/auth/session (validate current session)
 - ☐ GET /v1/users/me (get current user profile)
 - ☐ PATCH /v1/users/me (update profile)
- ☐ **Frontend Components**
 - ☐ Login page (email/password, Google, Facebook)
 - ☐ Signup page (email/password, Google, Facebook)
 - ☐ Email verification page
 - ☐ Password reset request page
 - ☐ Password reset completion page
 - ☐ Session expiry handling (auto-redirect to login)
 - ☐ Auth state management (Zustand/Redux store)

1.2 Phone Verification (Nigerian Market)

- ☐ **Database Schema**
 - ☐ userPhones table (userId, phone, normalized, verified, primary)
 - ☐ Indexes: by_user, by_phone
- ☐ **SMS Integration**
 - ☐ SMS provider integration (Termii or Twilio)

- [] OTP generation (6-digit, 10-minute expiry)
- [] OTP verification (hash comparison)
- [] Rate limiting (3 OTPs per hour per phone)
- [] Resend cooldown (60 seconds)
- [] Max attempts lockout (3 attempts, 15-minute lockout)
- [] **API Endpoints**
 - [] POST /v1/users/me/phone/send-otp
 - [] POST /v1/users/me/phone/verify-otp
 - [] GET /v1/users/me/phones (list all phones)
 - [] DELETE /v1/users/me/phones/:phoneId
 - [] POST /v1/users/me/phones/:phoneId/set-primary
- [] **Frontend Components**
 - [] Phone input component (Nigerian format: +234 XXX XXX XXXX)
 - [] Phone validation (10 digits, valid prefixes)
 - [] OTP verification modal (6-digit input, countdown timer)
 - [] Phone management UI (list, add, delete, set primary)
 - [] Verified phone badge in profile

1.3 Session & Security Management

- [] **Session Handling**
 - [] Secure session cookies (HttpOnly, SameSite, Secure)
 - [] Session expiry (7 days for web, 30 days for "remember me")
 - [] Session refresh (rolling sessions)
 - [] Multi-device session tracking
 - [] Session invalidation on password change
 - [] Concurrent session limit (10 devices max)
- [] **Security Monitoring**
 - [] Login attempt logging (IP, device, timestamp)
 - [] Suspicious activity detection (new device, new location)
 - [] Security event notifications (email on new login)
 - [] Account activity dashboard (view all sessions)
 - [] "Sign out all other devices" functionality
- [] **API Endpoints**
 - [] GET /v1/users/me/sessions (list active sessions)

- [] DELETE /v1/users/me/sessions/:sessionId (revoke one)
- [] POST /v1/users/me/sessions/revoke-all (logout everywhere)
- [] GET /v1/users/me/security-events (audit log)
- [] **Frontend Components**
 - [] Active sessions list (device, browser, IP, last active)
 - [] "Sign out" button per session
 - [] "Sign out all" confirmation modal
 - [] Security activity timeline

Category 2: Personal Account Management

2.1 User Profile System

- [] **Database Schema**
 - [] users table fields: firstName, lastName, displayName, avatarUrl, phone, country, timezone, language, status
 - [] userPreferences table: theme, notifications, regional settings
- [] **Profile Features**
 - [] Personal information management (name, display name, bio)
 - [] Profile photo upload (with cropping, compression)
 - [] Contact information (email, phone with verification status)
 - [] Regional settings (timezone, language, date format, currency display)
 - [] Display preferences (theme: light/dark/system)
 - [] Notification preferences (email, in-app, WhatsApp)
- [] **API Endpoints**
 - [] GET /v1/users/me (get full profile)
 - [] PATCH /v1/users/me (update profile)
 - [] POST /v1/users/me/avatar (upload avatar)
 - [] DELETE /v1/users/me/avatar (remove avatar)
 - [] GET /v1/users/me/preferences (get preferences)
 - [] PATCH /v1/users/me/preferences (update preferences)
 - [] GET /v1/users/me/identities (list connected OAuth providers)
 - [] DELETE /v1/users/me/identities/:provider (disconnect provider)
- [] **Frontend Components**
 - [] Profile settings page (tabs: Personal, Contact, Security, Preferences)
 - [] Profile photo upload component

- ☐ Name editing with validation
- ☐ Timezone selector (IANA timezones)
- ☐ Language selector
- ☐ Theme toggle (light/dark/system)
- ☐ Notification preferences form

2.2 Privacy & Data Controls

- ☐ **Database Schema**
 - ☐ `userConsents` table (consentType, version, granted, withdrawn, timestamp)
 - ☐ `dataExportRequests` table (userId, status, requestedAt, completedAt, storageReference)
 - ☐ `accountDeletionRequests` table (userId, status, requestedAt, scheduledDeletionAt, completedAt)
- ☐ **Privacy Features**
 - ☐ Terms of Service acceptance (versioned, tracked)
 - ☐ Privacy Policy acceptance (versioned, tracked)
 - ☐ Marketing consent (opt-in, can withdraw anytime)
 - ☐ Data export request (download all personal data as JSON/CSV)
 - ☐ Account deletion request (cooling-off period: 14 days)
 - ☐ Consent management dashboard (view, withdraw consents)
- ☐ **API Endpoints**
 - ☐ GET `/v1/users/me/consents` (list all consents)
 - ☐ PATCH `/v1/users/me/consents` (update marketing consent)
 - ☐ POST `/v1/users/me/data-export` (request data export)
 - ☐ GET `/v1/users/me/data-export/:exportId` (download export)
 - ☐ POST `/v1/users/me/deletion-request` (request account deletion)
 - ☐ POST `/v1/users/me/deletion-request/cancel` (cancel deletion)
- ☐ **Frontend Components**
 - ☐ Privacy settings page
 - ☐ Consent management UI (checkboxes for each consent type)
 - ☐ Data export request button with status
 - ☐ Account deletion request flow (multi-step confirmation)
 - ☐ "Download my data" button

Category 3: Organization/Workspace Management

3.1 Organization Schema & Lifecycle

- **[] Database Schema**
 - [] workspaces table (id, name, slug, type, ownerId, country, state, city, timezone, currency, logoUrl, status)
 - [] workspaceMemberships table (workspaceId, userId, status, role, invitedBy, invitedAt, acceptedAt, suspendedAt)
 - [] workspaceProducts table (workspaceId, productKey, status, planId, trialStartedAt, trialEndsAt, activatedBy, activatedAt)
 - [] workspaceAuditLogs table (workspaceId, actorUserId, eventType, entityType, entityId, severity, metadata, timestamp)
 - [] Indexes: by_owner, by_slug, by_status, by_user, by_workspace_user
- **[] Organization Lifecycle**
 - [] Organization creation (name, type, country, timezone, currency)
 - [] Organization update (settings, logo, contact details)
 - [] Organization archive (soft delete, preserve data)
 - [] Organization deletion (hard delete after 30-day grace period)
 - [] Ownership transfer (current owner → new owner)
 - [] Membership status management (invited, active, suspended, removed)
- **[] API Endpoints**
 - [] GET /v1/workspaces (list user's organizations)
 - [] POST /v1/workspaces (create new organization)
 - [] GET /v1/workspaces/:workspaceId (get organization details)
 - [] PATCH /v1/workspaces/:workspaceId (update organization)
 - [] POST /v1/workspaces/:workspaceId/archive (archive organization)
 - [] POST /v1/workspaces/:workspaceId/restore (restore archived org)
 - [] DELETE /v1/workspaces/:workspaceId (delete organization)
 - [] POST /v1/workspaces/:workspaceId/transfer-ownership (transfer to new owner)
 - [] GET /v1/workspaces/:workspaceId/context (get active org context)
- **[] Frontend Components**
 - [] Organization creation wizard (multi-step)
 - [] Organization selector dropdown (in app header)
 - [] Organization settings page (tabs: General, Members, Billing, Products)
 - [] Organization switcher (with loading state)
 - [] Empty state: "No organizations yet"

3.2 Membership & Invitations

- **[] Database Schema**
 - [] workspaceInvitations table (workspaceId, email, emailNormalized, invitedUserId, role, branchIds, tokenHash, status, invitedBy, expiresAt, acceptedAt, declinedAt)
 - [] Indexes: by_token_hash, by_email_status, by_invitee
- **[] Invitation System**
 - [] Invitation creation (email, role, branch access)
 - [] Invitation email sending (with secure token link)
 - [] Invitation acceptance flow (review org, role, branches → accept)
 - [] Invitation decline flow
 - [] Invitation expiry (7 days, auto-expire)
 - [] Invitation revocation (admin can revoke before acceptance)
 - [] Resend invitation (if expired or not received)
 - [] Token hashing (never store plaintext tokens)
- **[] Membership Management**
 - [] Member list (all members with roles, status, joined date)
 - [] Role assignment (Owner, Admin, Manager, Member)
 - [] Role editing (change member role)
 - [] Member suspension (temporary disable access)
 - [] Member removal (permanent remove from org)
 - [] Voluntary leave (member can leave org)
 - [] Owner protection (cannot remove last owner)
- **[] API Endpoints**
 - [] GET /v1/workspaces/:workspaceId/members (list members)
 - [] GET /v1/workspaces/:workspaceId/members/:membershipId (get member details)
 - [] PATCH /v1/workspaces/:workspaceId/members/:membershipId (update role)
 - [] POST /v1/workspaces/:workspaceId/members/:membershipId/suspend (suspend member)
 - [] POST /v1/workspaces/:workspaceId/members/:membershipId/restore (restore suspended member)
 - [] DELETE /v1/workspaces/:workspaceId/members/:membershipId (remove member)
 - [] POST /v1/workspaces/:workspaceId/invitations (invite new member)
 - [] GET /v1/workspaces/:workspaceId/invitations (list pending invitations)
 - [] POST /v1/workspaces/:workspaceId/invitations/:id/resend (resend invitation)

- [] POST /v1/workspaces/:workspaceId/invitations/:id/revoke (revoke invitation)
- [] GET /v1/users/me/invitations (list user's pending invitations)
- [] POST /v1/users/me/invitations/:id/accept (accept invitation)
- [] POST /v1/users/me/invitations/:id/decline (decline invitation)
- [] DELETE /v1/users/me/memberships/:workspaceId (leave organization)
- [] **Frontend Components**
 - [] Member management page (list, add, edit, remove)
 - [] Invitation modal (email input, role selector, branch access)
 - [] Pending invitations list (for org admin)
 - [] Invitation acceptance page (for invitee)
 - [] "Leave organization" confirmation modal

3.3 Nigerian Address & Phone for Organizations

- [] **Database Schema**
 - [] organizationPhones table (workspaceId, phone, phoneNormalized, isVerified, verificationCode, codeExpiresAt, verifiedAt)
 - [] organizationAddresses table (workspaceId, type, country, state, lga, city, area, street, blockNumber, landmark, postalCode, isDefault)
 - [] locations table (type, name, code, parentLocationId, stateCode) - Nigerian states & LGAs
 - [] Indexes: by_workspace, by_phone, by_state
- [] **Location Database**
 - [] Seed all 36 Nigerian states + FCT
 - [] Seed all 774 LGAs
 - [] API: GET /v1/locations/states (get all states)
 - [] API: GET /v1/locations/states/:stateCode/lgas (get LGAs by state)
 - [] Frontend: State dropdown (all states, sorted alphabetically)
 - [] Frontend: LGA dropdown (filtered by selected state)
- [] **Phone Verification**
 - [] Organization phone verification (OTP via SMS)
 - [] Option to use owner's verified phone (skip verification)
 - [] Option to add new business phone (requires OTP)
 - [] Phone validation (Nigerian format, valid prefixes)
 - [] OTP rate limiting (3 per hour)
 - [] Verified phone badge in org profile

- ☐ **Address Management**
 - ☐ Structured address form (Country → State → LGA → City → Area → Street → Block → Landmark)
 - ☐ Country fixed to "Nigeria" (not editable)
 - ☐ State dropdown (all 36 states + FCT)
 - ☐ LGA dropdown (filtered by selected state)
 - ☐ City/Area/Street/Block as text inputs
 - ☐ Landmark as optional text input
 - ☐ Postal code as optional (most users won't know)
 - ☐ Default address marked (headquarters)
 - ☐ Can add multiple addresses (billing, shipping)
- ☐ **API Endpoints**
 - ☐ POST /v1/workspaces/:workspaceId/phones/send-otp
 - ☐ POST /v1/workspaces/:workspaceId/phones/verify-otp
 - ☐ GET /v1/workspaces/:workspaceId/phones (list org phones)
 - ☐ POST /v1/workspaces/:workspaceId/addresses (add address)
 - ☐ PATCH /v1/workspaces/:workspaceId/addresses/:addressId (update address)
 - ☐ GET /v1/workspaces/:workspaceId/addresses (list org addresses)
- ☐ **Frontend Components**
 - ☐ Phone input component (Nigerian format)
 - ☐ OTP verification modal for org phone
 - ☐ Address form component (State → LGA → City → Street → Block)
 - ☐ Organization contact settings page
 - ☐ Verified phone badge

Category 4: Branch Management

4.1 Branch Schema & Operations

- ☐ **Database Schema**
 - ☐ branches table (workspaceId, name, code, isPrimary, status, phone, phoneNormalized, isPhoneVerified, country, state, lga, city, area, street, blockNumber, landmark)
 - ☐ Indexes: by_workspace, by_workspace_status, by_workspace_primary
- ☐ **Branch Lifecycle**
 - ☐ Branch creation (name, code, optional phone, optional address)

- ☐ Branch update (edit details)
- ☐ Branch archive (soft delete, preserve historical data)
- ☐ Primary branch designation (one per organization)
- ☐ Branch code uniqueness (within workspace)
- ☐ Default: copy address from organization (editable)
- ☐ **API Endpoints**
 - ☐ GET /v1/workspaces/:workspaceId/branches (list branches)
 - ☐ POST /v1/workspaces/:workspaceId/branches (create branch)
 - ☐ GET /v1/workspaces/:workspaceId/branches/:branchId (get branch details)
 - ☐ PATCH /v1/workspaces/:workspaceId/branches/:branchId (update branch)
 - ☐ POST /v1/workspaces/:workspaceId/branches/:branchId/archive (archive branch)
 - ☐ POST /v1/workspaces/:workspaceId/branches/:branchId/restore (restore branch)
- ☐ **Frontend Components**
 - ☐ Branch creation modal
 - ☐ Branch list/settings page
 - ☐ Branch selector dropdown (in app header, after org selector)
 - ☐ Branch edit modal
 - ☐ Branch archive confirmation

4.2 Branch Context & Switching

- ☐ **Context Management**
 - ☐ Active branch stored in frontend state (Zustand/Redux)
 - ☐ Branch context included in all API requests (header: x-branch-id)
 - ☐ Branch validation middleware (user has access to branch)
 - ☐ Branch switching triggers data refetch
 - ☐ URL updates with branch context (optional: ?branch=branch_789)
- ☐ **Branch Access Control**
 - ☐ Middleware: requireBranchAccess (validate user belongs to workspace + branch exists)
 - ☐ Error handling: 403 if branch not accessible
 - ☐ Empty state: "No branches yet" (create first branch)
 - ☐ Empty state: "No branch assigned" (for staff with no branch access)
- ☐ **Frontend Components**
 - ☐ Branch selector component (dropdown with all branches)
 - ☐ Current branch highlighted

- ☐ Primary branch badge
- ☐ Loading state during branch switch
- ☐ Branch switching confirmation (if unsaved changes)

Category 5: Onboarding System

5.1 Global Account Onboarding

- ☐ **Database Schema**
 - ☐ onboardingFlows table (userId, workspaceId, productKey, flowVersion, status, currentStep, completedSteps, skippedSteps, startedAt, lastUpdatedAt, completedAt)
 - ☐ onboardingEvents table (userId, workspaceId, productKey, step, eventType, metadata, createdAt)
 - ☐ Indexes: by_user, by_workspace_product
- ☐ **Onboarding Flow States**
 - ☐ pending_email_verification (email not verified)
 - ☐ pending_profile_setup (profile incomplete)
 - ☐ pending_organization_creation (no orgs yet)
 - ☐ pending_welcome (show welcome screen)
 - ☐ in_progress (onboarding in progress)
 - ☐ completed (onboarding finished)
- ☐ **Onboarding Steps**
 - ☐ Email verification (required)
 - ☐ Profile setup (firstName, lastName, timezone - required)
 - ☐ Phone verification (optional but encouraged)
 - ☐ Welcome screen (4 paths: create org, join org, explore, account)
 - ☐ Organization creation wizard (if user chooses)
 - ☐ Product selection (which apps to activate)
 - ☐ Plan selection (Free/Standard/Premium)
- ☐ **API Endpoints**
 - ☐ GET /v1/onboarding (get user's onboarding status)
 - ☐ POST /v1/onboarding/start (start onboarding flow)
 - ☐ PATCH /v1/onboarding/progress (update progress)
 - ☐ POST /v1/onboarding/complete-step (mark step complete)
 - ☐ POST /v1/onboarding/skip-step (skip optional step)
 - ☐ POST /v1/onboarding/complete (mark onboarding complete)

- ☐ POST /v1/onboarding/reset (restart onboarding)
- ☐ **Frontend Components**
 - ☐ Onboarding progress tracker (step 1 of 5)
 - ☐ Email verification screen
 - ☐ Profile setup form
 - ☐ Welcome screen (4 action cards)
 - ☐ Onboarding modal (can resume later)
 - ☐ "Continue setup" CTA in dashboard

5.2 Organization Creation Wizard

- ☐ **Wizard Steps**
 - ☐ Step 1: Organization Details (name, type, country, currency, timezone)
 - ☐ Step 2: Branch Setup (create first branch, name, code, address)
 - ☐ Step 3: Contact Details (phone verification, business address)
 - ☐ Step 4: Product Selection (which apps to activate: Inventory, Tasks, etc.)
 - ☐ Step 5: Plan Selection (Free/Standard/Premium)
 - ☐ Step 6: Team Invitation (optional: invite staff now or later)
 - ☐ Step 7: Completion (success message, redirect to dashboard)
- ☐ **Wizard Features**
 - ☐ Progress indicator (step X of 7)
 - ☐ Can go back/forward between steps
 - ☐ Validation before proceeding to next step
 - ☐ Can save progress and resume later
 - ☐ Auto-save draft organization if user exits mid-way
 - ☐ Success animation on completion
 - ☐ Redirect to branch dashboard after completion
- ☐ **Frontend Components**
 - ☐ Multi-step wizard component
 - ☐ Organization details form
 - ☐ Branch setup form
 - ☐ Contact details form (phone + address)
 - ☐ Product selection cards
 - ☐ Plan comparison table
 - ☐ Team invitation form

- [] Completion screen

5.3 Product Activation & Plan Selection

- [] Database Schema
 - [] plans table (key, name, monthlyPrice, annualPrice, currency, isActive)
 - [] subscriptions table (workspaceId, planKey, status, currentPeriodStart, currentPeriodEnd, cancelAtPeriodEnd)
 - [] workspaceEntitlements table (workspaceId, planId, featureKey, limitValue, source, status)
 - [] Indexes: by_key, by_workspace, by_plan
- [] Plan Configuration
 - [] Seed default plans: Free (¥0), Standard (¥7,500/month), Premium (¥20,000/month)
 - [] Plan limits hardcoded (Free: 1 org/1 app/2 members/500 products, Standard: 3 orgs/3 apps/10 members/5000 products, Premium: 10 orgs/unlimited apps/50 members/25000 products)
 - [] Plan entitlements service (check limits before resource creation)
 - [] Usage tracking (count orgs, apps, members, products per workspace)
- [] Product Activation
 - [] Product catalog (list of available apps: Inventory, Tasks, Gym, Bookings, CRM)
 - [] Product status management (active, coming_soon, draft)
 - [] Product activation per workspace (enable Inventory, Tasks, etc.)
 - [] Plan enforcement (Free: 1 app, Standard: 3 apps, Premium: all apps)
 - [] Usage limits checked before activation
- [] API Endpoints
 - [] GET /v1/plans (list available plans)
 - [] GET /v1/products (list available products)
 - [] POST /v1/workspaces/:workspaceId/products/:productKey/activate (activate product)
 - [] POST /v1/workspaces/:workspaceId/products/:productKey/deactivate (deactivate product)
 - [] GET /v1/workspaces/:workspaceId/entitlements (get plan entitlements)
 - [] GET /v1/workspaces/:workspaceId/usage (get current usage)
- [] Frontend Components
 - [] Product selection cards (with icons, descriptions)
 - [] Plan comparison table (Free vs Standard vs Premium)
 - [] Plan selection radio buttons

- [] Usage indicators (e.g., "2/3 apps used")
- [] "Activate" button for products
- [] Limit reached warning modal

5.4 Routing & Empty States

- [] **Routing Logic**
 - [] Unauthenticated → redirect to /login
 - [] Authenticated, email unverified → redirect to /verify-email
 - [] Authenticated, profile incomplete → redirect to /profile/setup
 - [] Authenticated, 0 orgs → show Welcome Screen (NOT redirect to org creation)
 - [] Authenticated, 1+ orgs → show Organization Selector or default org
 - [] Authenticated, 0 orgs, visiting /inventory → show "No organization yet" empty state
 - [] Authenticated, org exists but no Inventory activated → show "Activate Inventory" empty state
 - [] Authenticated, Inventory activated but no branch assigned → show "No branch assigned" empty state
- [] **Empty States**
 - [] Welcome Screen (4 actions: Create org, Join org, Explore, Account)
 - [] "No organizations yet" (create or join CTA)
 - [] "No branches yet" (create first branch CTA)
 - [] "Product not activated" (activate product CTA)
 - [] "No branch assigned" (contact admin CTA)
 - [] "No products available" (explore other apps CTA)
- [] **Frontend Components**
 - [] Welcome Screen component (hero section, 4 action cards)
 - [] Empty state components (with illustrations, CTAs)
 - [] Organization selector (dropdown with orgs)
 - [] Branch selector (dropdown with branches)
 - [] App launcher (grid of available apps)

Category 6: Super Admin System

6.1 Single Admin Authentication

- ☐ **Environment Configuration**
 - ☐ `ADMIN_USER_ID` environment variable (your user ID from database)
 - ☐ Admin user ID set after first account creation (one-time setup)
 - ☐ Admin user cannot be deleted via normal flows
- ☐ **Admin Middleware**
 - ☐ `requireSingleAdmin` middleware (check `request.user.id === process.env.ADMIN_USER_ID`)
 - ☐ Return 403 if not admin
 - ☐ Apply to all `/v1/admin/*` routes
- ☐ **Admin Session Management**
 - ☐ Admin sessions tracked separately (optional)
 - ☐ Admin session expiry: 1 hour (shorter than regular users)
 - ☐ Admin session audit logging (all admin actions logged)

6.2 Admin Dashboard & Capabilities

- ☐ **Admin Dashboard Features**
 - ☐ Overview dashboard (total users, total orgs, total branches, active subscriptions)
 - ☐ User management (list, search, view details, suspend, delete)
 - ☐ Organization management (list, search, view details, archive, delete)
 - ☐ Plan management (view/edit plan prices, toggle active/inactive)
 - ☐ Product management (create, edit, archive products; set status: active/coming_soon/draft)
 - ☐ Subscription management (view all subscriptions, manually change org plan)
 - ☐ Usage monitoring (view org usage, override limits temporarily)
 - ☐ Audit log viewer (platform-wide audit events)
 - ☐ Revenue overview (MRR, orgs by plan, cancelled subscriptions)
- ☐ **Admin API Endpoints**
 - ☐ `GET /v1/admin/stats` (platform stats)
 - ☐ `GET /v1/admin/users` (list all users)
 - ☐ `GET /v1/admin/users/:userId` (get user details)
 - ☐ `POST /v1/admin/users/:userId/suspend` (suspend user)
 - ☐ `POST /v1/admin/users/:userId/restore` (restore suspended user)
 - ☐ `DELETE /v1/admin/users/:userId` (delete user)
 - ☐ `GET /v1/admin/organizations` (list all orgs)

- [] GET /v1/admin/organizations/:workspaceId (get org details)
- [] POST /v1/admin/organizations/:workspaceId/archive (archive org)
- [] DELETE /v1/admin/organizations/:workspaceId (delete org)
- [] GET /v1/admin/plans (list all plans)
- [] PATCH /v1/admin/plans/:planKey (update plan price)
- [] GET /v1/admin/products (list all products)
- [] POST /v1/admin/products (create product)
- [] PATCH /v1/admin/products/:productKey (update product)
- [] POST /v1/admin/products/:productKey/archive (archive product)
- [] DELETE /v1/admin/products/:productKey (delete draft product)
- [] GET /v1/admin/subscriptions (list all subscriptions)
- [] POST /v1/admin/organizations/:workspaceId/subscription/change (change org plan)
- [] GET /v1/admin/organizations/:workspaceId/usage (view org usage)
- [] POST /v1/admin/organizations/:workspaceId/usage/override (override limit)
- [] GET /v1/admin/audit-logs (view platform audit logs)
- [] GET /v1/admin/revenue/overview (revenue dashboard)
- [] **Frontend Components**
 - [] Admin dashboard layout (sidebar navigation)
 - [] Stats overview cards
 - [] User list table (with search, filters)
 - [] User detail page
 - [] Organization list table
 - [] Organization detail page
 - [] Plan management page
 - [] Product management page (with status toggles)
 - [] Subscription management page
 - [] Usage monitoring dashboard
 - [] Audit log viewer (filterable table)
 - [] Revenue overview dashboard (charts, tables)

6.3 Product Launch Management

- ☐ **Product States**
 - ☐ active (visible to all users, can activate)
 - ☐ coming_soon (visible with badge, can join waitlist)
 - ☐ draft (hidden from users, admin-only)
- ☐ **Product Management**
 - ☐ Create product (name, description, icon, status, display order)
 - ☐ Edit product (all fields)
 - ☐ Archive product (soft delete, set status to draft)
 - ☐ Delete draft product (hard delete, only if status = draft)
 - ☐ Set product status (active/coming_soon/draft)
 - ☐ Set display order (sort order in app launcher)
 - ☐ Set beta flag (show "BETA" badge)
 - ☐ Set featured flag (highlight in launcher)
- ☐ **Waitlist Management**
 - ☐ productNotifyList table (productKey, email, userId, notified, createdAt)
 - ☐ Users can join waitlist for coming_soon products
 - ☐ Admin can view waitlist (count, emails)
 - ☐ Admin can export waitlist emails (CSV download)
 - ☐ Duplicate prevention (same email can't join twice)
- ☐ **API Endpoints**
 - ☐ GET /v1/admin/products (list all products including draft)
 - ☐ POST /v1/admin/products (create product)
 - ☐ PATCH /v1/admin/products/:productKey (update product)
 - ☐ POST /v1/admin/products/:productKey/archive (archive product)
 - ☐ DELETE /v1/admin/products/:productKey (delete draft)
 - ☐ GET /v1/admin/products/:productKey/notify-list (view waitlist)
 - ☐ GET /v1/admin/products/:productKey/notify-list/export (export emails)
 - ☐ POST /v1/products/:productKey/notify (user joins waitlist)
- ☐ **Frontend Components**
 - ☐ Product management page (list, create, edit)
 - ☐ Product edit modal (status selector, display order, beta/featured flags)
 - ☐ Waitlist viewer (count, email list)
 - ☐ Export waitlist button

- ☐ App launcher (shows active + coming_soon, hides draft)
- ☐ Coming Soon card with "Notify me" button

Category 7: Security & Compliance

7.1 Data Protection

- ☐ **Encryption**
 - ☐ Passwords hashed (bcrypt, 12 rounds minimum)
 - ☐ OTP codes hashed before storage
 - ☐ Session tokens encrypted
 - ☐ Phone numbers encrypted at rest (optional but recommended)
 - ☐ HTTPS enforced (no HTTP in production)
- ☐ **Access Control**
 - ☐ Zero-trust authorization (never trust client-supplied userId/workspaceId/branchId)
 - ☐ All queries scoped by workspaceId
 - ☐ All mutations validate ownership/membership
 - ☐ Row-level security in Convex (queries filter by workspace)
 - ☐ API middleware validates all context (user, workspace, branch)
- ☐ **Audit Logging**
 - ☐ All authentication events logged (login, logout, password change, phone verification)
 - ☐ All organization events logged (create, update, delete, member add/remove)
 - ☐ All admin actions logged (plan change, product management, user suspension)
 - ☐ Audit logs immutable (append-only)
 - ☐ Audit logs searchable by workspace, user, event type, date range
 - ☐ Retention policy: 2 years for security events, 1 year for operational events

7.2 Compliance (Nigerian Data Protection)

- ☐ **NDPR Requirements**
 - ☐ Privacy Policy page (accessible from all pages)
 - ☐ Terms of Service page (accessible from all pages)
 - ☐ Consent tracking (versioned, timestamped)
 - ☐ Data export functionality (user can download all personal data)
 - ☐ Account deletion functionality (user can request deletion)
 - ☐ Data retention policy documented

- ☐ Right to rectification (user can update their data)
- ☐ Data minimization (only collect necessary data)
- ☐ Purpose limitation (use data only for stated purposes)
- ☐ **Security Measures**
 - ☐ Rate limiting on all auth endpoints
 - ☐ Account lockout after failed attempts
 - ☐ Session timeout (7 days inactive)
 - ☐ Secure cookie flags (HttpOnly, SameSite, Secure)
 - ☐ CORS configuration (whitelist allowed origins)
 - ☐ Input validation (sanitize all user inputs)
 - ☐ SQL injection prevention (use parameterized queries)
 - ☐ XSS prevention (escape all outputs)

Category 8: Infrastructure & DevOps

8.1 Environment Setup

- ☐ **Development Environment**
 - ☐ Local development with subdomain routing (orv.iohub.localhost:4000, accounts.orv.iohub.localhost:4000, etc.)
 - ☐ .env file with all required variables:
 - ADMIN_USER_ID (your user ID)
 - DATABASE_URL (Convex deployment URL)
 - SMS_PROVIDER_API_KEY (Termii or Twilio)
 - GOOGLE_OAUTH_CLIENT_ID
 - GOOGLE_OAUTH_CLIENT_SECRET
 - FACEBOOK_OAUTH_APP_ID
 - FACEBOOK_OAUTH_APP_SECRET
 - JWT_SECRET or session signing key
 - FRONTEND_URL (for CORS)
 - ☐ Docker setup (optional but recommended for consistency)
 - ☐ Local Convex emulation (or use Convex cloud dev environment)
- ☐ **Production Environment**
 - ☐ Convex production deployment
 - ☐ Backend hosting (Vercel, Railway, or dedicated server)
 - ☐ Frontend hosting (Vercel, Netlify)

- ☐ Custom domain setup (orv.io/hub.com, accounts.orv.io/hub.com, etc.)
- ☐ SSL certificates (Let's Encrypt or hosting provider)
- ☐ Environment variables in hosting platform
- ☐ Database backups (automated daily)
- ☐ Monitoring (Sentry for errors, uptime monitoring)

8.2 CI/CD & Testing

- ☐ **Testing**
 - ☐ Unit tests for all auth functions (password hashing, OTP generation, session validation)
 - ☐ Integration tests for all API endpoints
 - ☐ E2E tests for critical flows (signup, login, org creation, onboarding)
 - ☐ Security tests (OWASP top 10: injection, XSS, CSRF, broken auth)
 - ☐ Load testing (100 concurrent users minimum)
 - ☐ Test coverage > 80% for auth/onboarding code
- ☐ **CI/CD Pipeline**
 - ☐ Automated tests on every PR
 - ☐ Automated deployment to staging on merge to develop
 - ☐ Automated deployment to production on merge to main
 - ☐ Database migrations run automatically
 - ☐ Rollback capability (one-click deploy previous version)
 - ☐ Deployment notifications (Slack/Email)

Category 9: Documentation & Support

9.1 Technical Documentation

- ☐ **API Documentation**
 - ☐ OpenAPI/Swagger spec for all endpoints
 - ☐ Authentication flow diagrams
 - ☐ Database schema documentation
 - ☐ Convex query/mutation documentation
 - ☐ Error codes and messages reference
- ☐ **Architecture Documentation**
 - ☐ System architecture diagram (frontend, backend, database, external services)
 - ☐ Data flow diagrams (auth flow, onboarding flow, org creation)

- ☐ Security architecture (session management, encryption, access control)
- ☐ Deployment architecture (hosting, domains, SSL)

9.2 User Documentation

- ☐ End User Guides
 - ☐ "Getting Started" guide (how to sign up, create org, complete onboarding)
 - ☐ "Managing Your Profile" guide
 - ☐ "Creating an Organization" guide
 - ☐ "Inviting Team Members" guide
 - ☐ "Switching Organizations/Branches" guide
 - ☐ FAQ (common questions about auth, onboarding, plans)
- ☐ Admin Guides
 - ☐ "Super Admin Dashboard" guide
 - ☐ "Managing Users" guide
 - ☐ "Managing Organizations" guide
 - ☐ "Managing Plans & Products" guide
 - ☐ "Handling Support Requests" guide

✓ Final Checklist: Ready to Build Apps?

Before starting Inventory/Task Management development, confirm:

Authentication & Account Management

- ☐ Users can sign up (email/password, Google, Facebook)
- ☐ Users can verify email
- ☐ Users can verify phone (Nigerian numbers)
- ☐ Users can log in/out
- ☐ Users can reset password
- ☐ Users can manage profile (name, avatar, contact, preferences)
- ☐ Users can manage security (sessions, 2FA if implemented)
- ☐ Users can export data and request deletion

Organization & Workspace

- ☐ Users can create organizations
- ☐ Users can join organizations via invitation
- ☐ Users can switch between organizations
- ☐ Users can manage organization settings
- ☐ Users can invite/remove members
- ☐ Organizations have verified phone and structured address

Branch Management

- ☐ Organizations can create branches
- ☐ Users can switch between branches
- ☐ Branches have optional phone and address
- ☐ Branch context validated on all requests

Onboarding

- ☐ Welcome screen shows 4 paths (create org, join org, explore, account)
- ☐ Organization creation wizard completes successfully
- ☐ Product selection and plan selection work
- ☐ Onboarding progress tracked and resumable
- ☐ Empty states show for all edge cases (0 orgs, 0 branches, no product access)

Super Admin

- ☐ You can access admin dashboard
- ☐ You can view/manage all users
- ☐ You can view/manage all organizations
- ☐ You can manage plans (edit prices)
- ☐ You can manage products (create, edit, set status)
- ☐ You can manually change org plans
- ☐ You can view usage and override limits

Security & Compliance

- ☐ All auth flows secure (password hashing, session management, rate limiting)
- ☐ NDPR compliance (privacy policy, consent tracking, data export, deletion)
- ☐ Audit logging for all critical events
- ☐ Zero-trust authorization (never trust client)

Infrastructure

- ☐ Development environment working (local subdomains)
- ☐ Production environment deployed (custom domains, SSL)
- ☐ SMS provider integrated (Termii/Twilio)
- ☐ OAuth providers configured (Google, Facebook)
- ☐ Database backups automated
- ☐ Monitoring in place (errors, uptime)

☑ If ALL items above are checked:

✓ You are ready to build actual applications (Inventory, Task Management, etc.)

✗ If ANY item is unchecked:

△ Fix the unchecked items first. Do not proceed to app development.

This is your complete authentication and onboarding foundation. Build this solid, and everything else will be easier.